

Event Information:

EventID :

316

Event Time :

Mar, 13, 2025, 09:44 AM

Rule :

SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing

Level :

Security Analyst

SMTP Address :

132.232.40.201

Source Address :

update@windows-update.site

Destination Address :

dylan@letsdefend.io

E-mail Subject :

Upgrade your system to Windows 11 Pro for FREE

Device Action :

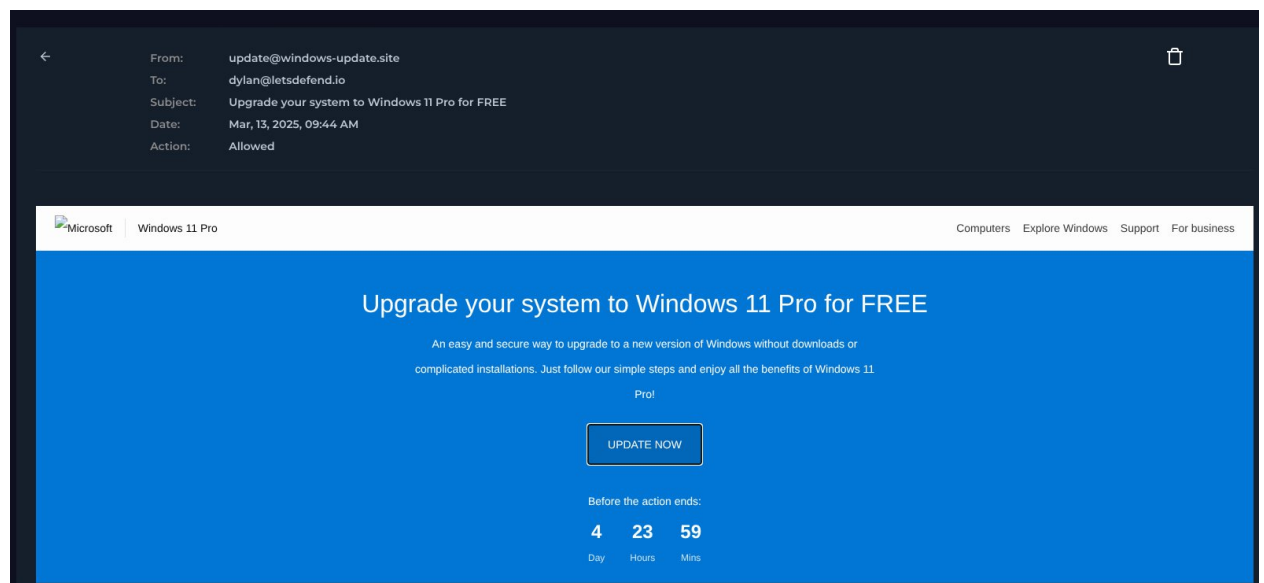
Allowed

Trigger Reason :

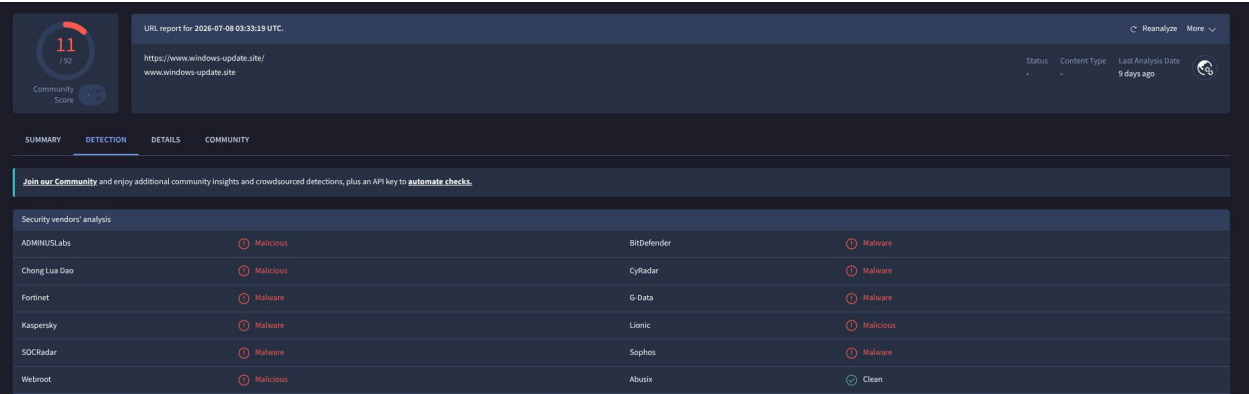
Redirected site contains a click fix type script for Lumma Stealer distribution.

Analysis Steps:

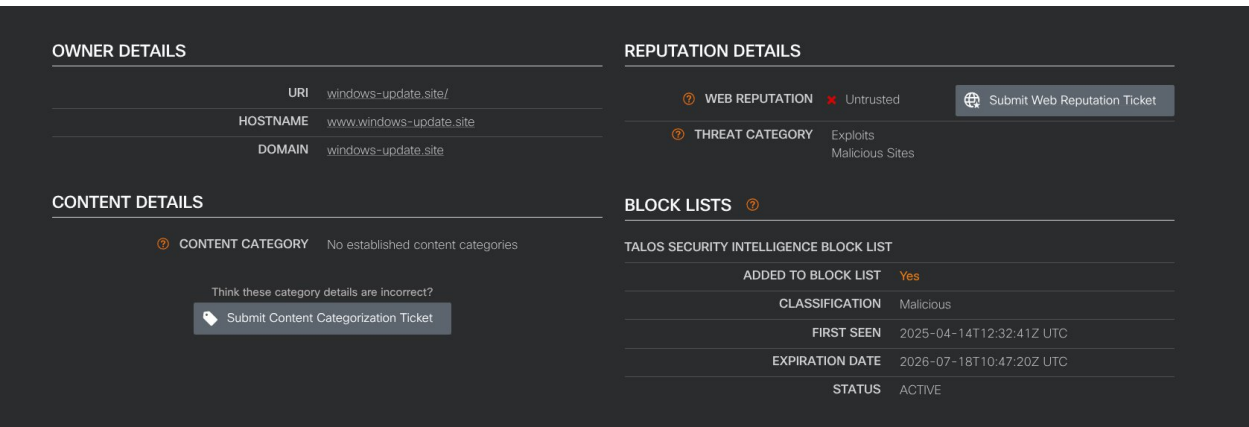
The email logs were searched for update[@]windows-update[.]site and the phishing email sent to dylan[@]letsdefend[.]io was found.



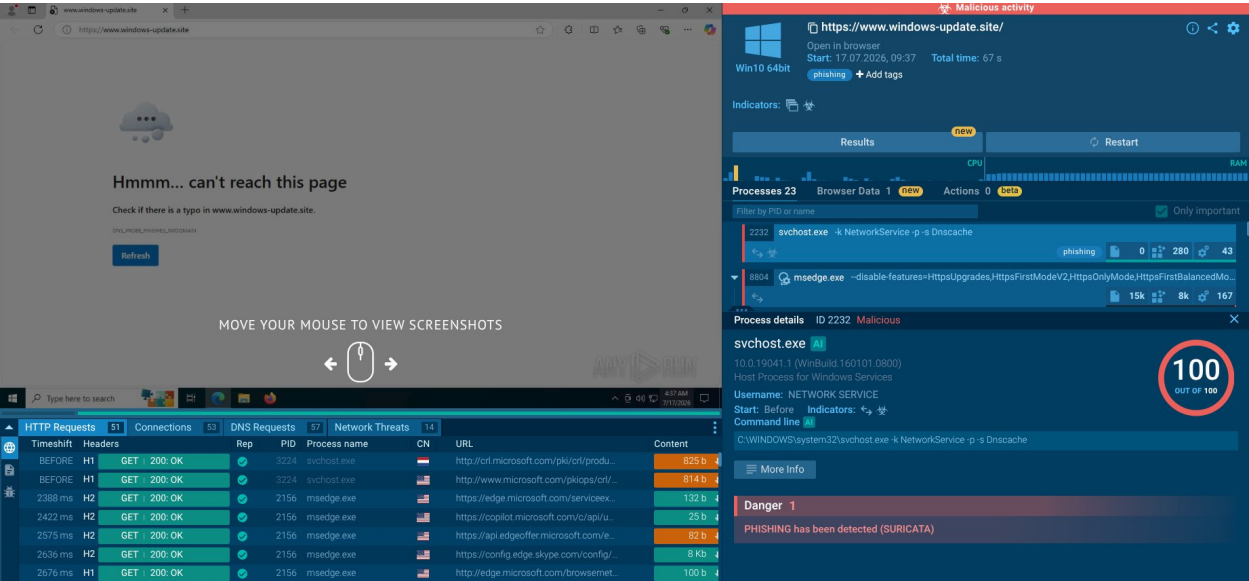
The site that the link leads to is listed as malicious by 11/91 Vendors on VirusTotal, most listing it as malware.



It is also listed as untrusted on Cisco Talos Intel.



When having AnyRun analyse the site the domain appears to be down. AnyRun's network monitor (SURICATA) saw a DNS request going out for a known phishing domain and appears to have immediately flagged it.



When checking the endpoint it can be seen in the relevant time-frame that malicious Powershell commands were run on the device which indicates compromise.

Processes	87
Network Action	28
Terminal History	3
Browser History	1
Results:	10

EVENT TIME	COMMAND LINE ↑
Mar 13 2025 23:26:31	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -Command "msht...
Mar 13 2025 23:26:19	"C:\Windows\system32\WindowsPowerShell\v1.0\PowerShell.exe" -w 1 powershel...
Mar 13 2025 23:26:32	"C:\Windows\system32\WindowsPowerShell\v1.0\PowerShell.exe" -w 1 powershel...

From these commands we can see:

"I am not a robot - reCAPTCHA Verification ID: 3824".

The malicious website presented a fake "Verify you are human" prompt. It could have instructed the user to copy this exact block of text and paste it into their terminal or "Run" window to pass the CAPTCHA.

The attacker used a string manipulation trick to hide their tools from basic antivirus software: ('ms]]]]ht]]]]a]]]].]]]exe' -replace ']').

The core of the script relies on mshta.exe (Microsoft HTML Application Host).

The command tells mshta.exe to reach out to the internet and execute the file at hxxps://overcoatpassably[.]shop/Z8UZbPyVpGfdRS/maloy.mp4.

Even though the URL ends in .mp4, it is almost certainly not a video file. It is a malicious script (likely an HTA or HTML Application file) disguised as a video to slip past network web filters.

The attacker also included -w 1 at the beginning of the PowerShell command. This is shorthand for -WindowStyle Hidden.

1 events (before Mar, 13, 2025, 11:26 PM UTC)	
1	
Hide Fields	
INTERESTING FIELDS	Event
type	source_address 172.16.17.216
source_address	source_port 34211
source_port	destination_address 172.67.139.19
destination_address	destination_port 443
destination_port	time Mar, 13, 2025, 11:26 PM
raw_log	Raw Log
	Process Name mshta.exe
	Process ID 7284
	Request URL https://overcoatpassably.shop/Z8UZbPyVpGfdRS/maloy.mp4
	Request Method GET
	Action Allowed

Because the firewall Action is listed as Allowed, the download was successful, bringing the Lumma Stealer payload directly onto the endpoint.

The offending IP is in our CTI database with the tag of Lumma Stealer.

DATE	DATA TYPE	DATA	TAG	DATA SOURCE
Mar, 13, 2025, 04:58 PM	IP	132.232.40.201	Lumma,Lumma Stealer	Anonymous

The IP is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a Chinese address associated with 132.[.]232.40.201 AS 45090 (Shenzhen Tencent Computer Systems Company Limited). 3/91 security vendors flagged this IP address as malicious.

3
/ 91
Community Score

3/91 security vendors flagged this IP address as malicious

132.232.40.201 (132.232.0.0/16)
AS 45090 (Shenzhen Tencent Computer Systems Company Limited)

ReanalyzeMore

OKLast Analysis Date
1 day ago

DETECTIONDETAILSRELATIONSCOMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

ADMINUSLabsMaliciousESETMalwareGridinsoftMaliciousAbusixCleanAcronisCleanAilabs (MONITORAPP)Clean

Do you want to automate checks?

On AbuseIPDB this IP was reported 5 times with a 0% confidence of abuse.

132.232.40.201 was found in our database!

This IP was reported 5 times. Confidence of Abuse is 0%?

0%

ISP

Tencent Cloud Computing (Beijing) Co., Ltd

Usage Type

Data Center/Web Hosting/Transit

ASN

[AS45090](#)

Domain Name

tencentcloud.com

Country

 China

City

Chengdu, Sichuan

The Lumma Stealer hosting domain `hxxps://overcoatpassably[.]shop` is not in our CTI database. On VirusTotal 14/91 Vendors list the domain as suspicious as of 10 days ago.

14
/ 92
Community Score

URL report for 2026-07-06 11:25:16 UTC.

https://overcoatpassably.shop/
overcoatpassably.shop

Reanalyze More

StatusContent TypeLast Analysis Date
- - 10 days ago

SUMMARYDETECTIONDETAILSCOMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

ADMINUSLabs	Malicious	alphaMountain.ai	Malicious
BitDefender	Phishing	Chong-Lua Dao	Malicious
CyRadlar	Malicious	Forcepoint ThreatSeeker	Malicious
Fortinet	Malware	G-Data	Phishing
Kaspersky	Malware	Lionic	Malicious
Rising	Malicious	Sophos	Malware
VIPRE	Malware	Webroot	Malicious
ESET	Suspicious	Gridinsoft	Suspicious
LevelBlue	Suspicious	Abusix	Clean

On Cisco Talos Intel it is listed as questionable but they also state that the domain is expired.

OWNER DETAILS

URIovercoatpassably.shop/
HOSTNAMEovercoatpassably.shop
DOMAINovercoatpassably.shop

CONTENT DETAILS

CONTENT CATEGORYNo established content categories

Think these category details are incorrect?
Submit Content Categorization Ticket

REPUTATION DETAILS

WEB REPUTATIONQuestionable
Submit Web Reputation Ticket

BLOCK LISTS

TALOS SECURITY INTELLIGENCE BLOCK LIST

ADDED TO BLOCK LIST	No
STATUS	EXPIRED

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a successful True Positive phishing attack leading to malware execution on the host endpoint. An external threat actor delivered a "Click Fix" phishing email to dylan[.]letsdefend[.]io, tricking the user, into what analysis suggests, as manually executing obfuscated PowerShell commands disguised as a CAPTCHA verification. This resulted in the successful download of a Lumma Stealer payload via a malicious .mp4 file.

Incident Details

- **Alert Name:** SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing
- **Target Account:** dylan[.]letsdefend[.]io
- **Attacker Email:** update[.]windows-update[.]site
- **Attacker IP:** 132[.]232.40.201
- **Device Action:** Allowed

Analysis and Evidence

- **Initial Access:** The user received an email titled "Upgrade your system to Windows 11 Pro for FREE". The embedded link directed the user to windows-update.site, which presented a fake "Verify you are human" prompt.
- **Execution:** Terminal history indicates the user followed the malicious prompt, pasting and executing a PowerShell command containing the string "I am not a robot - reCAPTCHA Verification ID: 3824".
- **Evasion & Download:** The executed script used string manipulation ('ms[.]ht[.]a[.]exe' -replace ']') and a hidden window flag (-w 1) to stealthily launch the Microsoft HTML Application Host. This built-in tool was instructed to download and execute a payload from `hxxps://overcoatpassably[.]shop/Z8UZbPyVpGfdRS/maloy.mp4`.
- **Success Confirmation:** Network logs show the firewall allowed the outbound GET request to the payload server, confirming the Lumma Stealer was successfully downloaded to the endpoint.

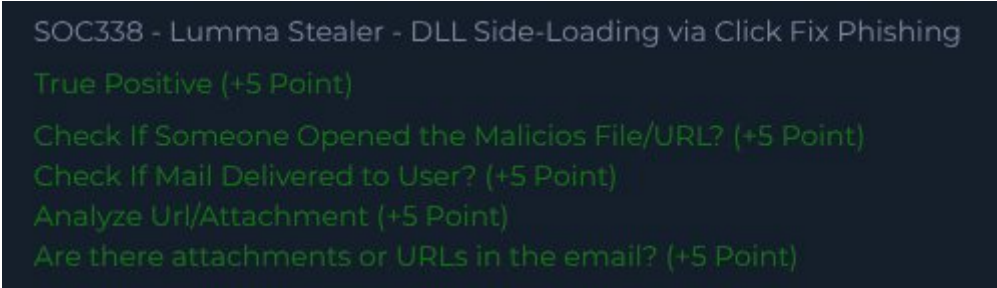
Threat Intelligence

- **Phishing Infrastructure:** The sender domain (windows-update.site) is flagged as malicious by 11/91 vendors on VirusTotal and is listed as untrusted by Cisco Talos. The source IP (132[.]232.40.201) resolves to Tencent in China and is tagged specifically for "Lumma Stealer" in the internal CTI database.
- **Payload Infrastructure:** The payload hosting domain (overcoatpassably[.]shop) is flagged as suspicious or malicious by 14/91 vendors on VirusTotal. On Cisco Talos, it is listed as questionable and expired.

Actions Taken

1. Analysed the phishing email and confirmed the malicious nature of the sender domain.
2. Reviewed endpoint terminal history, confirming the user executed the malicious "Click Fix" PowerShell commands.
3. Verified via network logs that the obfuscated mshta.exe command successfully downloaded the Lumma Stealer payload disguised as an .mp4 file.
4. Deleted the malicious email to prevent further compromise.
5. Isolated the affected endpoint from the network to contain the malware.
6. Declared the alert a True Positive and escalated.

Let's Defend Result



```
SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing
True Positive (+5 Point)
Check If Someone Opened the Malicious File/URL? (+5 Point)
Check If Mail Delivered to User? (+5 Point)
Analyze Url/Attachment (+5 Point)
Are there attachments or URLs in the email? (+5 Point)
```